

Appendix — finding detail

Art. 5 — Principles relating to processing

Priority: p2 Chapter: Ch.2 – Principles

Severity: warning Status: partial

Score: 20/100

Risk: medium

Gaps

- The policy does not explicitly state how data minimization is practiced.
- There is no clear mention of the specific retention periods or criteria for storage limitation.
- While some processing purposes are listed, a comprehensive statement on purpose limitation is not evident.
- The policy does not detail the specific measures taken to ensure data accuracy.
- Accountability principles, such as the designation of responsible individuals or internal record-keeping, are not clearly addressed.

Evidence

- The policy lists various types of personal data collected, including but not limited to Social Security Numbers, Date of Birth, Bank Account Information, Phone Numbers, IP addresses, survey responses, event information, blog comments, and social media information.
- The policy outlines how this information is used, such as for identity verification, account access, payment processing, communication, service improvement, research and development, fraud prevention, and to provide reasonable accommodation.
- It also details information shared with creators, including name, email address, messages, physical address, and phone number.

Notes

The policy addresses several aspects of Article 5, including transparency in data collection and use, and some elements of purpose limitation. However, it lacks explicit details on data minimization, accuracy, storage limitation, and accountability. The breadth of data collected and shared suggests a need for clearer policies on these principles to ensure full GDPR compliance.

```
{
  "article_number": 5,
  "article_title": "Principles relating to processing",
  "chapter": "Ch.2 - Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state how data minimization is practiced.",
    "There is no clear mention of the specific retention periods or criteria for storage limitation.",
    "While some processing purposes are listed, a comprehensive statement on purpose limitation is not evident.",
    "The policy does not detail the specific measures taken to ensure data accuracy.",
    "Accountability principles, such as the designation of responsible individuals or internal record-keeping, are not clearly addressed."
  ],
  "evidence": [
    "The policy lists various types of personal data collected, including but not limited to Social Security Numbers, Date of Birth, Bank Account Information, Phone Numbers, IP addresses, survey responses, event information, blog comments, and social media information.",
    "The policy outlines how this information is used, such as for identity verification, account access, payment processing, communication, service improvement, research and development, fraud prevention, and to provide reasonable accommodation.",
    "It also details information shared with creators, including name, email address, messages, physical address, and phone number."
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy addresses several aspects of Article 5, including transparency in data collection and use, and some elements of purpose limitation. However, it lacks explicit details on data minimization, accuracy, storage limitation, and accountability. The breadth of data collected and shared suggests a need for clearer policies on these principles to ensure full GDPR compliance.",
  "article_material_used": "text"
}
```

Art. 6 — Lawfulness of processing

Priority: p2 Chapter: Ch.2 – Principles

Severity: critical Status: fail

Score: 0/100

Risk: critical

Gaps

• Article 6: Lawfulness of processing - No lawful basis is stated for any of the processing activities described in the provided policy chunks.

Notes

The policy chunks describe various processing activities including collecting and storing blog information, using cookies and social media features, processing membership payments, sending emails, sharing information with creators and third parties, and complying with laws. However, none of these activities are linked to a lawful basis as required by Article 6 of the GDPR.

```
{
  "article_number": 6,
  "article_title": "Lawfulness of processing",
  "chapter": "Ch.2 – Principles",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "Article 6: Lawfulness of processing - No lawful basis is stated for any of the processing activities described in the provided policy chunks."
  ],
  "evidence": [],
  "risk": "critical",
  "needs_human_review": false,
  "notes": "The policy chunks describe various processing activities including collecting and storing blog information, using cookies and social media features, processing membership payments, sending emails, sharing information with creators and third parties, and complying with laws. However, none of these activities are linked to a lawful basis as required by Article 6 of the GDPR.",
  "article_material_used": "summary"
}
```

Art. 7 — Conditions for consent

Priority: p2 Chapter: Ch.2 – Principles

Severity: warning Status: partial

Score: 36/100

Risk: medium

Gaps

- The policy does not explicitly state that consent must be freely given and unambiguous.
- While marketing consent can be opted out of, the policy does not detail the process for withdrawing consent for other types of processing.
- The policy does not clearly define what constitutes 'informed' consent, particularly regarding the granularity of information provided before consent is obtained.

Evidence

- The policy states 'By agreeing to our terms of use, you expressly agree that Patreon may: [...] send you messages related to services we provide which are separate from your existing service via email, from which you may opt out.' (c25)
- The policy mentions 'send you marketing emails or texts if you don't have a Patreon account but have consented to receiving such messages, from which you may opt out.' (c25)
- The policy states 'You may object to the use of your data for marketing purposes at any time, free of charge, when we collect your personal information and in every marketing communication. You may also object to the use of your data for marketing upon creation of your account or anytime thereafter, by opting out here.' (c26)
- The policy states 'Opting out will stop marketing emails. Please allow up to 30 days for your opt-out request to be processed.' (c26)

Notes

The policy addresses opt-out mechanisms for marketing, which is a form of withdrawal. However, it lacks explicit statements on consent being freely given and unambiguous, and the process for withdrawing consent

for non-marketing purposes is not detailed. The 'informed' aspect of consent is also not clearly elaborated upon.

```
{
  "article_number": 7,
  "article_title": "Conditions for consent",
  "chapter": "Ch.2 – Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state that consent must be freely given and unambiguous.",
    "While marketing consent can be opted out of, the policy does not detail the process for withdrawing consent for other types of processing.",
    "The policy does not clearly define what constitutes 'informed' consent, particularly regarding the granularity of information provided before consent is obtained."
  ],
  "evidence": [
    "The policy states 'By agreeing to our terms of use, you expressly agree that Patreon may: [...] send you messages related to services we provide which are separate from your existing service via email, from which you may opt out.' (c25)",
    "The policy mentions 'send you marketing emails or texts if you don't have a Patreon account but have consented to receiving such messages, from which you may opt out.' (c25)",
    "The policy states 'You may object to the use of your data for marketing purposes at any time, free of charge, when we collect your personal information and in every marketing communication. You may also object to the use of your data for marketing upon creation of your account or anytime thereafter, by opting out here.' (c26)",
    "The policy states 'Opting out will stop marketing emails. Please allow up to 30 days for your opt-out request to be processed.' (c26)"
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy addresses opt-out mechanisms for marketing, which is a form of withdrawal. However, it lacks explicit statements on consent being freely given and unambiguous, and the process for withdrawing consent for non-marketing purposes is not detailed. The 'informed' aspect of consent is also not clearly elaborated upon.",
  "article_material_used": "text"
}
```

Art. 8 — Child's consent

Priority: p3 Chapter: Ch.2 – Principles
Severity: warning Status: present (unverified)
Score: 70/100
Notes

The policy explicitly states that the service is not directed at children under 13 and that children cannot create an account or use the service. This directly addresses the age limitation aspect of Article 8. However, it does not mention parental consent mechanisms.

```
{
  "article_number": 8,
  "article_title": "Child's consent",
  "chapter": "Ch.2 – Principles",
  "priority": "p3",
  "policy_present": true,
  "implementation_unverified": true,
  "needs_human_review": true,
  "evidence": "Patreon is not directed at children under the age of 13, and children may not create an account or otherwise use Patreon.",
  "notes": "The policy explicitly states that the service is not directed at children under 13 and that children cannot create an account or use the service. This directly addresses the age limitation aspect of Article 8. However, it does not mention parental consent mechanisms.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 9 — Special category data

Priority: p2 Chapter: Ch.2 – Principles
Severity: warning Status: partial
Score: 52/100
Risk: high
Gaps

- The policy mentions collecting demographic information including ethnicity and race in [c12] and [c13], which are special category data under Article 9. However, it does not explicitly state that explicit consent or a specific

derogation under Article 9(2) is obtained for this processing, nor does it detail the specific purposes for which this data is processed beyond 'to better understand and serve our user base' and 'to ensure we provide fair and equal access to our services'.

Evidence

- Policy chunk [c12] states: 'We may ask you demographic information, including information related to your gender, ethnicity, race, age, sexual orientation, earnings, and accessibility to better understand and serve our user base which you may elect to share or not.'
- Policy chunk [c13] states: 'This information may include... demographic information...'
- Article 9(2) of GDPR outlines the conditions under which special category data can be processed, such as explicit consent (Art. 9(2)(a)) or other specific derogations.

Notes

While the policy indicates that users may elect to share demographic information and that this data is collected to 'better understand and serve our user base', it does not clearly articulate the basis for processing special category data (Article 9). Explicit consent or a specific legal ground from Article 9(2) is required for processing sensitive data like ethnicity and race. The stated purposes are vague and may not sufficiently justify the processing without explicit consent.

```
{
  "article_number": 9,
  "article_title": "Special category data",
  "chapter": "Ch.2 - Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy mentions collecting demographic information including ethnicity and race in [
c12] and [c13], which are special category data under Article 9. However, it does not
explicitly state that explicit consent or a specific derogation under Article 9(2) is obtained
for this processing, nor does it detail the specific purposes for which this data is processed
beyond 'to better understand and serve our user base' and 'to ensure we provide fair and equal
access to our services'."
  ],
  "evidence": [
    "Policy chunk [c12] states: 'We may ask you demographic information, including information
related to your gender, ethnicity, race, age, sexual orientation, earnings, and accessibility
to better understand and serve our user base which you may elect to share or not.'",
    "Policy chunk [c13] states: 'This information may include... demographic information...'",
    "Article 9(2) of GDPR outlines the conditions under which special category data can be
processed, such as explicit consent (Art. 9(2)(a)) or other specific derogations."
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "While the policy indicates that users may elect to share demographic information
and that this data is collected to 'better understand and serve our user base', it does not
clearly articulate the basis for processing special category data (Article 9). Explicit consent
or a specific legal ground from Article 9(2) is required for processing sensitive data like
ethnicity and race. The stated purposes are vague and may not sufficiently justify the
processing without explicit consent.",
  "article_material_used": "summary"
}
```

Art. 10 — Criminal convictions data

Priority: p3 Chapter: Ch.2 – Principles

Severity: critical Status: missing

Score: 0/100

```
{
  "article_number": 10,
  "article_title": "Criminal convictions data",
  "chapter": "Ch.2 - Principles",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": null,
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 11 — Processing without identification

Priority: p2 Chapter: Ch.2 – Principles

Severity: warning Status: partial

Score: 36/100

Risk: high

Gaps

- No mention of processing without identification in the provided policy chunks.
- No information regarding anonymisation or pseudonymisation claims being consistent with data minimisation language is available.
- The policy chunks define pseudonymisation but do not elaborate on its application in the context of processing without identification.

Evidence

- The provided text includes definitions for 'personal data' and 'processing' under Article 4.
- Article 4(5) defines 'pseudonymisation' as processing personal data such that it cannot be attributed to a specific data subject without additional information, provided that the additional information is kept separately and secured.

Notes

The provided policy chunks do not contain sufficient information to assess compliance with GDPR Article 11 regarding processing without identification. While pseudonymisation is defined, there is no explicit mention of its use in this context or any claims about its consistency with data minimisation. Therefore, compliance cannot be confirmed, leading to a high risk.

```
{
  "article_number": 11,
  "article_title": "Processing without identification",
  "chapter": "Ch.2 – Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "No mention of processing without identification in the provided policy chunks.",
    "No information regarding anonymisation or pseudonymisation claims being consistent with data minimisation language is available.",
    "The policy chunks define pseudonymisation but do not elaborate on its application in the context of processing without identification."
  ],
  "evidence": [
    "The provided text includes definitions for 'personal data' and 'processing' under Article 4.",
    "Article 4(5) defines 'pseudonymisation' as processing personal data such that it cannot be attributed to a specific data subject without additional information, provided that the additional information is kept separately and secured."
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The provided policy chunks do not contain sufficient information to assess compliance with GDPR Article 11 regarding processing without identification. While pseudonymisation is defined, there is no explicit mention of its use in this context or any claims about its consistency with data minimisation. Therefore, compliance cannot be confirmed, leading to a high risk.",
  "article_material_used": "text"
}
```

Art. 12 — Transparency & modalities

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: critical Status: fail

Score: 0/100

Risk: medium

Gaps

- The policy does not explicitly state a commitment to respond to data subject requests within one month, as required by Article 12(3).
- The policy does not explicitly mention providing information in an electronic and commonly used format, or the right to have the information transferred to another controller, as outlined in Article 12(5).

- While the policy mentions that objections to marketing are free of charge (Article 12(5)), it doesn't explicitly state that **all** information provided under Article 12 requests will be free of charge.

Evidence

- c21 9930-11130
- c22 10930-11939
- c23 11939-12592
- c24 12592-12925
- c25 12925-14125
- c26 13925-15076
- c27 15076-16276

Notes

The policy addresses several aspects of transparency and user rights, including opt-out options for marketing, access to settings, and account deletion/data export. However, specific commitments regarding the one-month response period for requests, providing information electronically, and ensuring all such information is free of charge (beyond marketing opt-outs) are not clearly articulated. The policy should be updated to explicitly cover these points to fully comply with Article 12.

```
{
  "article_number": 12,
  "article_title": "Transparency & modalities",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not explicitly state a commitment to respond to data subject requests within one month, as required by Article 12(3).",
    "The policy does not explicitly mention providing information in an electronic and commonly used format, or the right to have the information transferred to another controller, as outlined in Article 12(5).",
    "While the policy mentions that objections to marketing are free of charge (Article 12(5)), it doesn't explicitly state that *all* information provided under Article 12 requests will be free of charge."
  ],
  "evidence": [
    "c21 9930-11130",
    "c22 10930-11939",
    "c23 11939-12592",
    "c24 12592-12925",
    "c25 12925-14125",
    "c26 13925-15076",
    "c27 15076-16276"
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy addresses several aspects of transparency and user rights, including opt-out options for marketing, access to settings, and account deletion/data export. However, specific commitments regarding the one-month response period for requests, providing information electronically, and ensuring all such information is free of charge (beyond marketing opt-outs) are not clearly articulated. The policy should be updated to explicitly cover these points to fully comply with Article 12.",
  "article_material_used": "summary"
}
```

Art. 13 — Info collected from data subject

Priority: p2 **Chapter:** Ch.3 – Rights of data subjects

Severity: warning **Status:** partial

Score: 12/100

Risk: medium

Gaps

- Controller ID is not mentioned.
- Data Protection Officer (DPO) contact information is not mentioned.
- Legal basis for processing is not explicitly stated.
- Data retention periods are not specified.
- Information about recipients of personal data is incomplete.
- Summary of data subject rights is not provided.

Evidence

- {'legally_required': 'No', 'finding': "The policy does not explicitly state the Controller's ID.", 'article': 'Article 13'}
- {'legally_required': 'No', 'finding': "The policy does not explicitly state the DPO's contact information.", 'article': 'Article 13'}
- {'legally_required': 'Yes', 'finding': 'The policy does not explicitly state the legal basis for processing personal data.', 'article': 'Article 13(1)(c)'}
- {'legally_required': 'Yes', 'finding': 'The policy does not specify the retention period for personal data.', 'article': 'Article 13(2)(a)'}
- {'legally_required': 'Yes', 'finding': 'While some recipients are mentioned (creators, third-party analytics providers like Discourse and Discord), a comprehensive list or categories of recipients is not provided.', 'article': 'Article 13(1)(e)'}
- {'legally_required': 'Yes', 'finding': "The policy does not include a summary of the data subject's rights.", 'article': 'Article 13(2)(b)'}

Notes

The provided text covers various types of data collected, how it's used, and shared with creators and third parties. However, it lacks several key elements required by Article 13, such as controller identification, DPO contact, explicit legal basis, retention periods, a comprehensive list of recipients, and a summary of data subject rights. This leads to a partial compliance status and a medium risk assessment.

```
{
  "article_number": 13,
  "article_title": "Info collected from data subject",
  "chapter": "Ch.3 - Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "Controller ID is not mentioned.",
    "Data Protection Officer (DPO) contact information is not mentioned.",
    "Legal basis for processing is not explicitly stated.",
    "Data retention periods are not specified.",
    "Information about recipients of personal data is incomplete.",
    "Summary of data subject rights is not provided."
  ],
  "evidence": [
    {
      "legally_required": "No",
      "finding": "The policy does not explicitly state the Controller's ID.",
      "article": "Article 13"
    },
    {
      "legally_required": "No",
      "finding": "The policy does not explicitly state the DPO's contact information.",
      "article": "Article 13"
    },
    {
      "legally_required": "Yes",
      "finding": "The policy does not explicitly state the legal basis for processing personal data.",
      "article": "Article 13(1)(c)"
    },
    {
      "legally_required": "Yes",
      "finding": "The policy does not specify the retention period for personal data.",
      "article": "Article 13(2)(a)"
    },
    {
      "legally_required": "Yes",
      "finding": "While some recipients are mentioned (creators, third-party analytics providers like Discourse and Discord), a comprehensive list or categories of recipients is not provided.",
      "article": "Article 13(1)(e)"
    },
    {
      "legally_required": "Yes",
      "finding": "The policy does not include a summary of the data subject's rights.",
      "article": "Article 13(2)(b)"
    }
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The provided text covers various types of data collected, how it's used, and shared with creators and third parties. However, it lacks several key elements required by Article 13, such as controller identification, DPO contact, explicit legal basis, retention periods, a comprehensive list of recipients, and a summary of data subject rights. This leads to a partial compliance status and a medium risk assessment."
}
```

```

    "article_material_used": "text"
  }

```

Art. 14 — Info not obtained from data subject

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: critical Status: fail

Score: 0/100

Risk: high

Gaps

- The policy does not explicitly state what information will be provided to data subjects when their data is not obtained directly from them, as required by GDPR Article 14(1).
- The policy does not specify the categories of personal data concerned (Art. 14(2)(c)), the source of the data (Art. 14(2)(d)), or whether the data was subject to any special safeguards if transferred to a third country or international organisation (Art. 14(2)(f)).
- The policy lacks information on the existence of automated decision-making, including profiling, and its implications for the data subject (Art. 14(2)(g)).
- The policy does not mention the data subject's rights, such as the right to rectification or erasure, or the right to restrict or object to processing (Art. 14(2)(e)).

Evidence

- The provided text includes definitions from GDPR Article 4, but it does not contain policy text directly addressing the requirements of GDPR Article 14 regarding information to be provided when data is not obtained from the data subject.
- The policy does not contain any clauses that explicitly outline the procedures or content related to Article 14 of the GDPR.

Notes

The policy is missing critical information required by GDPR Article 14. Specifically, it fails to detail the information that must be provided to data subjects when their personal data is not obtained from them. This includes the categories of data, the source of the data, the data subject's rights, and information about automated decision-making. The absence of this information poses a significant compliance risk.

```

{
  "article_number": 14,
  "article_title": "Info not obtained from data subject",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not explicitly state what information will be provided to data subjects when their data is not obtained directly from them, as required by GDPR Article 14(1).",
    "The policy does not specify the categories of personal data concerned (Art. 14(2)(c)), the source of the data (Art. 14(2)(d)), or whether the data was subject to any special safeguards if transferred to a third country or international organisation (Art. 14(2)(f)).",
    "The policy lacks information on the existence of automated decision-making, including profiling, and its implications for the data subject (Art. 14(2)(g)).",
    "The policy does not mention the data subject's rights, such as the right to rectification or erasure, or the right to restrict or object to processing (Art. 14(2)(e))."
  ],
  "evidence": [
    "The provided text includes definitions from GDPR Article 4, but it does not contain policy text directly addressing the requirements of GDPR Article 14 regarding information to be provided when data is not obtained from the data subject.",
    "The policy does not contain any clauses that explicitly outline the procedures or content related to Article 14 of the GDPR."
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy is missing critical information required by GDPR Article 14. Specifically, it fails to detail the information that must be provided to data subjects when their personal data is not obtained from them. This includes the categories of data, the source of the data, the data subject's rights, and information about automated decision-making. The absence of this information poses a significant compliance risk.",
  "article_material_used": "text"
}

```

Art. 15 — Right of access

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: critical Status: fail

Score: 0/100

Risk: high

Gaps

- The policy does not describe the process for submitting a Subject Access Request (SAR).
- The policy does not specify the timeframe within which a response to a SAR will be provided.
- The policy does not outline the procedures for verifying the identity of the data subject making the SAR.
- The policy does not clearly state what specific types of personal data will be provided in response to a SAR, beyond listing categories of collected information.

Evidence

- c7 3064-3152
- c8 3152-3306
- c9 3306-3319
- c10 3319-3353
- c11 3353-4361
- c12 4361-4908
- c13 4908-5333
- c14 5333-5556

Notes

While the policy details the types of personal data collected and how it is used, it fails to describe the process for exercising the right of access under Article 15. Key components such as the SAR submission process, response timeline, identity verification, and the specific scope of information provided are missing.

```
{
  "article_number": 15,
  "article_title": "Right of access",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not describe the process for submitting a Subject Access Request (SAR).",
    "The policy does not specify the timeframe within which a response to a SAR will be provided.",
    "The policy does not outline the procedures for verifying the identity of the data subject making the SAR.",
    "The policy does not clearly state what specific types of personal data will be provided in response to a SAR, beyond listing categories of collected information."
  ],
  "evidence": [
    "c7 3064-3152",
    "c8 3152-3306",
    "c9 3306-3319",
    "c10 3319-3353",
    "c11 3353-4361",
    "c12 4361-4908",
    "c13 4908-5333",
    "c14 5333-5556",
    "c15 5556-6756",
    "c16 6556-6902",
    "c17 6902-6930",
    "c18 6930-8130",
    "c19 7930-9130"
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "While the policy details the types of personal data collected and how it is used, it fails to describe the process for exercising the right of access under Article 15. Key components such as the SAR submission process, response timeline, identity verification, and the specific scope of information provided are missing.",
  "article_material_used": "summary"
}
```

Art. 16 — Right to rectification

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: critical Status: fail

Score: 0/100

Risk: high

Gaps

- The provided policy text does not explicitly describe the right to rectification for personal data, nor does it mention the 'without undue delay' requirement for corrections or updates as stipulated by GDPR Article 16.

Evidence

- No policy chunk explicitly addresses Article 16: Right to rectification or the 'without undue delay' clause.

Notes

The policy text does not contain information relevant to GDPR Article 16, specifically the right to rectification and the associated 'without undue delay' timeframe for corrections. This is a significant gap.

```
{
  "article_number": 16,
  "article_title": "Right to rectification",
  "chapter": "Ch.3 - Rights of data subjects",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The provided policy text does not explicitly describe the right to rectification for personal data, nor does it mention the 'without undue delay' requirement for corrections or updates as stipulated by GDPR Article 16."
  ],
  "evidence": [
    "No policy chunk explicitly addresses Article 16: Right to rectification or the 'without undue delay' clause."
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy text does not contain information relevant to GDPR Article 16, specifically the right to rectification and the associated 'without undue delay' timeframe for corrections. This is a significant gap.",
  "article_material_used": "text"
}
```

Art. 17 — Right to erasure

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 52/100

Risk: low

Gaps

- The policy does not explicitly describe the grounds for refusing a deletion request, nor does it detail any specific retention exceptions that would override the right to erasure.

Evidence

- {'policy_chunk_id': 'c27 15076-16276', 'excerpt': 'Deleting Your Account\nYou may self-initiate a deletion of your account directly at privacy.patreon.com, clicking on the Take Control button, and submitting an “Erase” request. Please be aware that this is a final act and cannot be reversed. If you would like to transport your data, please be sure to download your data first,'}
- {'policy_chunk_id': 'c26 13925-15076', 'excerpt': 'Accessing, Updating or Exporting the Information in Your Account\nYou can access and update certain information associated with your account on the settings pages. Additionally, you can delete your account, or export your personal information, by going to privacy.patreon.com.'}

Notes

The policy adequately describes the process for initiating an account deletion (right to erasure) via privacy.patreon.com and emphasizes that it is a final and irreversible action. It also advises users to download their data first. However, it lacks details on specific grounds for refusal or any exceptions to the right to erasure.

```
{
  "article_number": 17,
  "article_title": "Right to erasure",
  "chapter": "Ch.3 - Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly describe the grounds for refusing a deletion request, nor does it detail any specific retention exceptions that would override the right to erasure."
  ],
  "evidence": [
```

```

{
  "policy_chunk_id": "c27 15076-16276",
  "excerpt": "Deleting Your Account\nYou may self-initiate a deletion of your account directly at privacy.patreon.com, clicking on the Take Control button, and submitting an \"Erase\" request. Please be aware that this is a final act and cannot be reversed. If you would like to transport your data, please be sure to download your data first,"
},
{
  "policy_chunk_id": "c26 13925-15076",
  "excerpt": "Accessing, Updating or Exporting the Information in Your Account\nYou can access and update certain information associated with your account on the settings pages. Additionally, you can delete your account, or export your personal information, by going to privacy.patreon.com."
}
],
"risk": "low",
"needs_human_review": false,
"notes": "The policy adequately describes the process for initiating an account deletion (right to erasure) via privacy.patreon.com and emphasizes that it is a final and irreversible action. It also advises users to download their data first. However, it lacks details on specific grounds for refusal or any exceptions to the right to erasure.",
"article_material_used": "text"
}

```

Art. 18 — Right to restriction

Priority: p2 **Chapter:** Ch.3 – Rights of data subjects

Severity: warning **Status:** partial

Score: 52/100

Risk: medium

Gaps:

- The policy mentions the right to restrict or oppose the processing of personal data, but does not explicitly detail the process or circumstances under which this right is granted or denied, nor does it clearly define what 'restriction of processing' entails in practice beyond 'marking stored personal data with the aim of limiting their processing in the future'.

Evidence:

- **RELEVANT POLICY CHUNKS:** [c31 19119-20319] Users in certain locations may have certain rights under the General Data Protection Regulation (GDPR) or under the California Consumer Privacy Act (CCPA) regarding data that Patreon controls as a Data Controller as defined under the GDPR, including: ... the right to restrict or oppose the processing of personal data

- Art.4 definitions excerpt for terminology: (3) 'restriction of processing' means the marking of stored personal data with the aim of limiting their processing in the future;

Notes:

The policy acknowledges the right to restrict processing as per GDPR Article 18. However, it lacks specific details on how this right is exercised or implemented, beyond a general statement and definition. This may lead to uncertainty for users on how to enforce this right and for the company on its obligations beyond marking data.

```

{
  "article_number": 18,
  "article_title": "Right to restriction",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy mentions the right to restrict or oppose the processing of personal data, but does not explicitly detail the process or circumstances under which this right is granted or denied, nor does it clearly define what 'restriction of processing' entails in practice beyond 'marking stored personal data with the aim of limiting their processing in the future'."
  ],
  "evidence": [
    "RELEVANT POLICY CHUNKS: [c31 19119-20319] Users in certain locations may have certain rights under the General Data Protection Regulation (GDPR) or under the California Consumer Privacy Act (CCPA) regarding data that Patreon controls as a Data Controller as defined under the GDPR, including: ... the right to restrict or oppose the processing of personal data",
    "Art.4 definitions excerpt for terminology: (3) 'restriction of processing' means the marking of stored personal data with the aim of limiting their processing in the future;"
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy acknowledges the right to restrict processing as per GDPR Article 18. However, it lacks specific details on how this right is exercised or implemented, beyond a

```

```

general statement and definition. This may lead to uncertainty for users on how to enforce this
right and for the company on its obligations beyond marking data.",
  "article_material_used": "summary"
}

```

Art. 19 — Notification on rectification/erasure

Priority: p3 **Chapter:** Ch.3 – Rights of data subjects

Severity: critical **Status:** missing

Score: 0/100

Notes

The policy text does not contain any information about notifying recipients of rectification or erasure of personal data. The provided chunks discuss data sharing with third parties, legal disclosures, and account deletion, but not the specific notification requirement under Article 19.

```

{
  "article_number": 19,
  "article_title": "Notification on rectification/erasure",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy text does not contain any information about notifying recipients of
rectification or erasure of personal data. The provided chunks discuss data sharing with third
parties, legal disclosures, and account deletion, but not the specific notification requirement
under Article 19.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 20 — Right to data portability

Priority: p2 **Chapter:** Ch.3 – Rights of data subjects

Severity: critical **Status:** fail

Score: 0/100

Risk: high

Gaps

- The policy does not explicitly mention the right to data portability in a structured, machine-readable format.
- The policy does not address the right of a data subject to transmit personal data from one controller to another.

Evidence

- The provided text discusses data collection for blogs (c14), cookies and social media features (c15), and how information is used and shared (c18, c19, c20, c21). None of these sections describe the right to data portability or controller-to-controller transfer.
- The definitions excerpt (Art.4) explains terms like 'personal data', 'processing', 'controller', and 'recipient' but does not cover the specifics of Article 20.

Notes

Article 20 of GDPR grants data subjects the right to receive their personal data in a structured, commonly used, and machine-readable format and to transmit such data to another controller. The provided policy text does not contain any information related to this right.

```

{
  "article_number": 20,
  "article_title": "Right to data portability",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not explicitly mention the right to data portability in a structured,
machine-readable format.",
    "The policy does not address the right of a data subject to transmit personal data from one
controller to another."
  ],
  "evidence": [
    "The provided text discusses data collection for blogs (c14), cookies and social media

```

```

features (c15), and how information is used and shared (c18, c19, c20, c21). None of these
sections describe the right to data portability or controller-to-controller transfer.",
"The definitions excerpt (Art.4) explains terms like 'personal data', 'processing',
'controller', and 'recipient' but does not cover the specifics of Article 20."
],
"risk": "high",
"needs_human_review": false,
"notes": "Article 20 of GDPR grants data subjects the right to receive their personal data in
a structured, commonly used, and machine-readable format and to transmit such data to another
controller. The provided policy text does not contain any information related to this right.",
"article_material_used": "text"
}

```

Art. 21 — Right to object

Priority: p2 **Chapter:** Ch.3 – Rights of data subjects

Severity: critical **Status:** fail

Score: 0/100

Risk: high

Gaps:

- The policy does not explicitly state how users can object to direct marketing or profiling. While it mentions 'Choosing Your Preferences' and 'Marketing Activities', it lacks clear opt-out mechanisms for direct marketing and profiling as required by Article 21.

Evidence:

- **RELEVANT POLICY CHUNKS:** [c24 12925-12925] Choosing Your Preferences The Settings link is located by clicking on your avatar or profile at the top right hand of your screen, after your log into your Patreon account. Settings lets you see your account preferences. You can see and adjust your settings by viewing your preferences and, if you wish, by changing your selections. [c25 12925-14125] Marketing Activities By agreeing to our terms of use, you expressly agree that Patreon may: provide you with information about your service, service enhancements, or new Patreon products, while you are on our web site or using our apps. send you messages regarding your existing service, or enhancements related to your existing service,

Notes:

Article 21 requires a clear and explicit right to object to direct marketing and profiling. The provided text discusses preferences and marketing activities but does not detail how a user can exercise their right to object to these specific processing activities. The policy implies that users can adjust settings but doesn't confirm this extends to objecting to profiling or direct marketing.

```

{
  "article_number": 21,
  "article_title": "Right to object",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not explicitly state how users can object to direct marketing or profiling.
    While it mentions 'Choosing Your Preferences' and 'Marketing Activities', it lacks clear opt-
    out mechanisms for direct marketing and profiling as required by Article 21."
  ],
  "evidence": [
    "RELEVANT POLICY CHUNKS: [c24 12925-12925] Choosing Your Preferences The Settings link is
    located by clicking on your avatar or profile at the top right hand of your screen, after your
    log into your Patreon account. Settings lets you see your account preferences. You can see and
    adjust your settings by viewing your preferences and, if you wish, by changing your selections.
    [c25 12925-14125] Marketing Activities By agreeing to our terms of use, you expressly agree
    that Patreon may: provide you with information about your service, service enhancements, or new
    Patreon products, while you are on our web site or using our apps. send you messages regarding
    your existing service, or enhancements related to your existing service,"
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "Article 21 requires a clear and explicit right to object to direct marketing and
  profiling. The provided text discusses preferences and marketing activities but does not detail
  how a user can exercise their right to object to these specific processing activities. The
  policy implies that users can adjust settings but doesn't confirm this extends to objecting to
  profiling or direct marketing.",
  "article_material_used": "summary"
}

```

Art. 22 — Automated decision-making

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: critical Status: fail

Score: 0/100

Risk: critical

Gaps

- The policy does not explicitly mention the right to obtain human intervention, express one's point of view, and to contest the automated decision.
- The policy does not clearly state that individuals have the right to not be subject to solely automated decision-making that produces legal or similarly significant effects.
- The policy does not detail the specific circumstances or safeguards under which automated decision-making might be permissible (e.g., with explicit consent or for contract necessity).

Evidence

- Policy Chunk c11 mentions the collection of 'Automatically Collected Information' such as device information, IP address, pages visited, user interactions, and search terms. It also notes that forum participation involves collecting comments, IP addresses, and login locations. This indicates automated data collection and processing.
- Policy Chunk c11 states that 'We use Discourse and Discord to help us host and operate our Forums. This means that they may access your information to help provide the Forum.' This implies potential automated decision-making or processing by third parties.
- Policy Chunk c28 states 'Patreon is an international company that complies with the General Data Protection Regulation (GDPR). We act as Data Controllers, as defined under the GDPR, and process personal data based on our legitimate interests, and for contractual necessity in providing you the Service as described in "How We Use Your Information." We also process and share personal information based on notification and users' consent, which our users may revoke at any time.' While this confirms GDPR compliance, it does not detail Article 22 specific rights.
- Policy Chunk c30 mentions that Patreon 'provides California residents, and all users, the right to view, access, or transport their information at the Patreon Privacy Center. All users also have the right to submit a request for deletion of information by going to the Patreon Privacy Center, clicking on the "Take Control" button, and requesting "Erase."' These rights pertain to data access and deletion, not specifically to automated decision-making.
- Article 4(4) of GDPR defines 'profiling' as 'any form of automated processing of personal data consisting of the use of personal data to evaluate certain personal aspects relating to a natural person...'. This definition is relevant to understanding automated decision-making but is not a policy statement from the company.

Notes

The policy acknowledges GDPR compliance but fails to address the specific rights outlined in Article 22 concerning automated decision-making, including the right to object, the right to human intervention, and the right to contest such decisions. The automated data collection described in chunk c11 could potentially lead to profiling or automated decisions that fall under Article 22, yet the policy provides no information on how these rights are upheld.

```
{
  "article_number": 22,
  "article_title": "Automated decision-making",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not explicitly mention the right to obtain human intervention, express one's point of view, and to contest the automated decision.",
    "The policy does not clearly state that individuals have the right to not be subject to solely automated decision-making that produces legal or similarly significant effects.",
    "The policy does not detail the specific circumstances or safeguards under which automated decision-making might be permissible (e.g., with explicit consent or for contract necessity).",
  ],
  "evidence": [
    "Policy Chunk c11 mentions the collection of 'Automatically Collected Information' such as device information, IP address, pages visited, user interactions, and search terms. It also notes that forum participation involves collecting comments, IP addresses, and login locations. This indicates automated data collection and processing.",
    "Policy Chunk c11 states that 'We use Discourse and Discord to help us host and operate our Forums. This means that they may access your information to help provide the Forum.' This implies potential automated decision-making or processing by third parties.",
```

"Policy Chunk c28 states 'Patreon is an international company that complies with the General Data Protection Regulation (GDPR). We act as Data Controllers, as defined under the GDPR, and process personal data based on our legitimate interests, and for contractual necessity in providing you the Service as described in "How We Use Your Information." We also process and share personal information based on notification and users' consent, which our users may revoke at any time.' While this confirms GDPR compliance, it does not detail Article 22 specific rights."

"Policy Chunk c30 mentions that Patreon 'provides California residents, and all users, the right to view, access, or transport their information at the Patreon Privacy Center. All users also have the right to submit a request for deletion of information by going to the Patreon Privacy Center, clicking on the "Take Control" button, and requesting "Erase."' These rights pertain to data access and deletion, not specifically to automated decision-making."

"Article 4(4) of GDPR defines 'profiling' as 'any form of automated processing of personal data consisting of the use of personal data to evaluate certain personal aspects relating to a natural person...'. This definition is relevant to understanding automated decision-making but is not a policy statement from the company."

```

    ],
    "risk": "critical",
    "needs_human_review": false,
    "notes": "The policy acknowledges GDPR compliance but fails to address the specific rights outlined in Article 22 concerning automated decision-making, including the right to object, the right to human intervention, and the right to contest such decisions. The automated data collection described in chunk c11 could potentially lead to profiling or automated decisions that fall under Article 22, yet the policy provides no information on how these rights are upheld.",
    "article_material_used": "text"
  }

```

Art. 24 — Responsibility of the controller

Priority: p2 **Chapter:** Ch.4 – Controller & processor

Severity: warning **Status:** partial

Score: 36/100

Risk: medium

Gaps

- The policy does not explicitly detail the appointment and responsibilities of a Data Protection Officer (DPO) as required by Article 38(1).
- While the policy mentions contracts with third parties to safeguard data, it does not specify the mechanisms for ensuring ongoing compliance by these processors as required by Article 28(1) and Article 24(2).
- The policy lacks specific details on how the controller implements mechanisms to demonstrate compliance with data protection principles (Art. 5), such as regular audits, impact assessments, or documented internal procedures beyond contractual obligations with processors.

Evidence

- RELEVANT POLICY CHUNKS: [c21 9930-11130], [c22 10930-11939], [c23 11939-12592], [c24 12592-12925], [c25 12925-14125], [c26 13925-15076], [c27 15076-16276]
- Article 24 (1) requires the controller to implement appropriate technical and organisational measures to ensure and to be able to demonstrate that processing is performed in accordance with this Regulation.
- Article 24 (2) requires the controller to take into account the nature, scope, context and purposes of processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, when implementing measures.
- Article 28 (1) states that where processing is to be carried out on behalf of the controller, the controller shall use only processors providing sufficient guarantees to implement appropriate technical and organisational measures in such a manner that processing will meet the requirements of this Regulation and ensure the protection of the rights of the data subject.

Notes

The policy demonstrates an understanding of controller responsibilities regarding data security and third-party agreements. However, it lacks explicit detail on demonstrating ongoing compliance and the specific internal mechanisms for accountability beyond contractual clauses. The absence of information regarding a DPO and detailed compliance demonstration procedures leads to a partial status and medium risk.

```

{
  "article_number": 24,
  "article_title": "Responsibility of the controller",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",

```

```

"gap": [
  "The policy does not explicitly detail the appointment and responsibilities of a Data Protection Officer (DPO) as required by Article 38(1).",
  "While the policy mentions contracts with third parties to safeguard data, it does not specify the mechanisms for ensuring ongoing compliance by these processors as required by Article 28(1) and Article 24(2).",
  "The policy lacks specific details on how the controller implements mechanisms to demonstrate compliance with data protection principles (Art. 5), such as regular audits, impact assessments, or documented internal procedures beyond contractual obligations with processors."
],
"evidence": [
  "RELEVANT POLICY CHUNKS: [c21 9930-11130], [c22 10930-11939], [c23 11939-12592], [c24 12592-12925], [c25 12925-14125], [c26 13925-15076], [c27 15076-16276]",
  "Article 24 (1) requires the controller to implement appropriate technical and organisational measures to ensure and to be able to demonstrate that processing is performed in accordance with this Regulation.",
  "Article 24 (2) requires the controller to take into account the nature, scope, context and purposes of processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, when implementing measures.",
  "Article 28 (1) states that where processing is to be carried out on behalf of the controller, the controller shall use only processors providing sufficient guarantees to implement appropriate technical and organisational measures in such a manner that processing will meet the requirements of this Regulation and ensure the protection of the rights of the data subject."
],
"risk": "medium",
"needs_human_review": false,
"notes": "The policy demonstrates an understanding of controller responsibilities regarding data security and third-party agreements. However, it lacks explicit detail on demonstrating ongoing compliance and the specific internal mechanisms for accountability beyond contractual clauses. The absence of information regarding a DPO and detailed compliance demonstration procedures leads to a partial status and medium risk.",
"article_material_used": "summary"
}

```

Art. 25 — Privacy by design and default

Priority: p3 **Chapter:** Ch.4 – Controller & processor

Severity: critical **Status:** missing

Score: 0/100

Notes:

The provided text discusses data collection, usage, sharing, and user preferences, but it does not explicitly mention or address the principles of 'privacy by design' or 'privacy by default' as required by Article 25 of the GDPR. While some sections touch upon default settings for public display of creators supported (c23), this is not sufficient to constitute a material mention of the core concepts of PbD/PbDf.

```

{
  "article_number": 25,
  "article_title": "Privacy by design and default",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided text discusses data collection, usage, sharing, and user preferences, but it does not explicitly mention or address the principles of 'privacy by design' or 'privacy by default' as required by Article 25 of the GDPR. While some sections touch upon default settings for public display of creators supported (c23), this is not sufficient to constitute a material mention of the core concepts of PbD/PbDf.",
  "status": null,
  "gap": [],
  "risk": null
}

```

Art. 26 — Joint controllers

Priority: p3 **Chapter:** Ch.4 – Controller & processor

Severity: warning **Status:** present (unverified)

Score: 70/100

Notes:

The provided text includes definitions relevant to Article 26, specifically the definition of 'controller', which inherently covers joint controllership. The definition implies that the determination of purposes and means can

be made by multiple entities. Thus, the policy materially addresses the topic.

```
{
  "article_number": 26,
  "article_title": "Joint controllers",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": true,
  "implementation_unverified": true,
  "needs_human_review": true,
  "evidence": "The definition of 'controller' in Article 4(7) explicitly states 'determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law'. This wording implies that multiple entities can be controllers, either 'alone or jointly with others', thus addressing the concept of joint controllership.",
  "notes": "The provided text includes definitions relevant to Article 26, specifically the definition of 'controller', which inherently covers joint controllership. The definition implies that the determination of purposes and means can be made by multiple entities. Thus, the policy materially addresses the topic.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 27 — Representatives (non-EU)

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

Notes

The provided policy text contains definitions from GDPR Article 4, but does not address the specific requirements of Article 27 concerning the appointment of a representative for non-EU entities.

```
{
  "article_number": 27,
  "article_title": "Representatives (non-EU)",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided policy text contains definitions from GDPR Article 4, but does not address the specific requirements of Article 27 concerning the appointment of a representative for non-EU entities.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 28 — Processor / DPA

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: warning Status: partial

Score: 44/100

Risk: medium

Gaps

- The policy mentions that creators agree to a Data Processing Agreement (DPA) called the Creator Privacy Promise, but the specific clauses required by Article 28 (sub-processor list, audit rights, deletion/return obligation, written instructions) are not detailed in the provided text. It is assumed that the DPA contains these provisions, but direct evidence is missing.

- The policy states that service providers are 'obligated by contract to safeguard any of your data they receive from us to the same extent that Patreon protects it,' which implies adherence to GDPR principles. However, explicit details regarding audit rights, sub-processor lists, deletion/return obligations, and the requirement for written instructions for these processors are not present in the text.

Evidence

- Creators agree to the terms of our Data Processing Agreement (DPA) when they start their membership program. This DPA is called the Creator Privacy Promise.

- These companies [service providers] may have access to your data to perform their services, and are obligated by contract to safeguard any of your data they receive from us to the same extent that Patreon protects it.

Notes

The policy references a DPA (Creator Privacy Promise) that creators must agree to, which suggests that Article 28 requirements are addressed. It also mentions service providers are contractually obligated to safeguard data to the same extent as Patreon. However, the specific details of the DPA's compliance with Article 28 clauses (sub-processors, audit rights, deletion/return, written instructions) are not provided in the text, leading to a partial status and medium risk due to the lack of explicit verification of these crucial contractual terms.

```
{
  "article_number": 28,
  "article_title": "Processor / DPA",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy mentions that creators agree to a Data Processing Agreement (DPA) called the Creator Privacy Promise, but the specific clauses required by Article 28 (sub-processor list, audit rights, deletion/return obligation, written instructions) are not detailed in the provided text. It is assumed that the DPA contains these provisions, but direct evidence is missing.",
    "The policy states that service providers are 'obligated by contract to safeguard any of your data they receive from us to the same extent that Patreon protects it,' which implies adherence to GDPR principles. However, explicit details regarding audit rights, sub-processor lists, deletion/return obligations, and the requirement for written instructions for these processors are not present in the text."
  ],
  "evidence": [
    "Creators agree to the terms of our Data Processing Agreement (DPA) when they start their membership program. This DPA is called the Creator Privacy Promise.",
    "These companies [service providers] may have access to your data to perform their services, and are obligated by contract to safeguard any of your data they receive from us to the same extent that Patreon protects it."
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy references a DPA (Creator Privacy Promise) that creators must agree to, which suggests that Article 28 requirements are addressed. It also mentions service providers are contractually obligated to safeguard data to the same extent as Patreon. However, the specific details of the DPA's compliance with Article 28 clauses (sub-processors, audit rights, deletion/return, written instructions) are not provided in the text, leading to a partial status and medium risk due to the lack of explicit verification of these crucial contractual terms.",
  "article_material_used": "text"
}
```

Art. 29 — Processing under authority

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: critical Status: fail

Score: 0/100

Risk: high

Gaps

- The policy does not contain explicit information regarding the documentation of instruction chains for processing under the authority of the controller or processor, as required by Article 29.

Evidence

- The provided policy chunks define key terms like 'personal data', 'processing', 'controller', 'processor', and 'third party' (Articles 4(1), 4(2), 4(7), 4(8), 4(10)). However, they do not detail the requirement for documenting the instruction chain under which a processor or third party operates, which is the core of Article 29.

Notes

Article 29 requires that where a processor or other third party processes personal data, they do so only on instructions from the controller. The policy must demonstrate that these instructions are documented. The current policy lacks this specific documentation requirement.

```
{
  "article_number": 29,
  "article_title": "Processing under authority",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
```

```

    "status": "fail",
    "gaps": [
      "The policy does not contain explicit information regarding the documentation of
instruction chains for processing under the authority of the controller or processor, as
required by Article 29."
    ],
    "evidence": [
      "The provided policy chunks define key terms like 'personal data', 'processing',
'controller', 'processor', and 'third party' (Articles 4(1), 4(2), 4(7), 4(8), 4(10)). However,
they do not detail the requirement for documenting the instruction chain under which a
processor or third party operates, which is the core of Article 29."
    ],
    "risk": "high",
    "needs_human_review": false,
    "notes": "Article 29 requires that where a processor or other third party processes personal
data, they do so only on instructions from the controller. The policy must demonstrate that
these instructions are documented. The current policy lacks this specific documentation
requirement.",
    "article_material_used": "text"
  }

```

Art. 30 — Records of processing (ROPA)

Priority: p2 **Chapter:** Ch.4 – Controller & processor

Severity: warning **Status:** partial

Score: 20/100

Risk: medium

Gaps:

- The policy does not explicitly state the purposes of processing for all categories of data. While some purposes are implied (e.g., providing services, analytics, marketing), a clear, consolidated list for each processing activity is missing.
- The policy does not explicitly detail all categories of data subjects whose personal data is processed.
- While categories of recipients are mentioned (third-party apps, partners, public authorities in legal processes), a comprehensive list of all potential recipients for each processing activity is not provided.
- Specific retention periods for different categories of personal data are not clearly defined. The policy mentions storing survey responses and collected information but lacks explicit timelines for erasure or anonymization.
- While general security measures are implied by contract obligations with third parties, the policy does not explicitly detail the technical and organizational security measures implemented by the controller for all processing activities.

Evidence:

- Policy Chunk c7: Mentions collection of Address, Social Security Number or Employer Identification Number, Country of Citizenship.
- Policy Chunk c8: Mentions collection of Foreign Tax Identification Number, Date of Birth, Nonprofit Registration Number, Bank Account Information for Payouts.
- Policy Chunk c9: Mentions collection of Phone Number.
- Policy Chunk c10: Mentions collection of Additional Information.
- Policy Chunk c11: Details automatically collected information (device type, OS, browser, IP address, pages visited, links clicked, search terms, location) and information collected from forums/messaging (comments, visit frequency, activity, communication logs, private messages, IP address, login location).
- Policy Chunk c12: Details user surveys collecting demographic information (gender, ethnicity, race, age, sexual orientation, earnings, accessibility).
- Policy Chunk c13: Details event information collection (name, email, payment details, mobile phone number, QR code, demographic info, social media links, work types, survey responses).
- Policy Chunk c21: Mentions disclosure to third parties for legal processes, sales/mergers, and third-party apps/partners.

Notes:

The policy provides a good overview of the types of data collected and some of the contexts for processing. However, it lacks the specific detail required by Article 30 regarding the explicit purposes for each processing activity, a comprehensive list of data subjects, detailed recipient categories for all processing, specific retention periods, and explicit descriptions of security measures. This results in a partial compliance status.

{

```

"article_number": 30,
"article_title": "Records of processing (ROPA)",
"chapter": "Ch.4 – Controller & processor",
"priority": "p2",
"status": "partial",
"gaps": [
  "The policy does not explicitly state the purposes of processing for all categories of data. While some purposes are implied (e.g., providing services, analytics, marketing), a clear, consolidated list for each processing activity is missing.",
  "The policy does not explicitly detail all categories of data subjects whose personal data is processed.",
  "While categories of recipients are mentioned (third-party apps, partners, public authorities in legal processes), a comprehensive list of all potential recipients for each processing activity is not provided.",
  "Specific retention periods for different categories of personal data are not clearly defined. The policy mentions storing survey responses and collected information but lacks explicit timelines for erasure or anonymization.",
  "While general security measures are implied by contract obligations with third parties, the policy does not explicitly detail the technical and organizational security measures implemented by the controller for all processing activities."
],
"evidence": [
  "Policy Chunk c7: Mentions collection of Address, Social Security Number or Employer Identification Number, Country of Citizenship.",
  "Policy Chunk c8: Mentions collection of Foreign Tax Identification Number, Date of Birth, Nonprofit Registration Number, Bank Account Information for Payouts.",
  "Policy Chunk c9: Mentions collection of Phone Number.",
  "Policy Chunk c10: Mentions collection of Additional Information.",
  "Policy Chunk c11: Details automatically collected information (device type, OS, browser, IP address, pages visited, links clicked, search terms, location) and information collected from forums/messaging (comments, visit frequency, activity, communication logs, private messages, IP address, login location).",
  "Policy Chunk c12: Details user surveys collecting demographic information (gender, ethnicity, race, age, sexual orientation, earnings, accessibility).",
  "Policy Chunk c13: Details event information collection (name, email, payment details, mobile phone number, QR code, demographic info, social media links, work types, survey responses).",
  "Policy Chunk c21: Mentions disclosure to third parties for legal processes, sales/mergers, and third-party apps/partners.",
  "Policy Chunk c22: Mentions connecting social accounts (Twitter, Facebook, Google, YouTube, Twitch) and collecting social information (follower counts, post counts, view/like/comment counts).",
  "Policy Chunk c23: States what information is publicly accessible (profile, social links, location, supported creators, posts, likes, comments, aggregated usage data, pledge values, number of patrons).",
  "Policy Chunk c25: Mentions marketing activities involving providing information about services and sending messages."
],
"risk": "medium",
"needs_human_review": false,
"notes": "The policy provides a good overview of the types of data collected and some of the contexts for processing. However, it lacks the specific detail required by Article 30 regarding the explicit purposes for each processing activity, a comprehensive list of data subjects, detailed recipient categories for all processing, specific retention periods, and explicit descriptions of security measures. This results in a partial compliance status.",
"article_material_used": "summary"
}

```

Art. 32 — Security of processing

Priority: p3 **Chapter:** Ch.4 – Controller & processor

Severity: critical **Status:** missing

Score: 0/100

Notes

The policy text focuses on data collection, types of data collected, and user interaction with the platform. It does not contain any information regarding encryption, access controls, incident response, or testing, which are key components of Article 32 of the GDPR concerning the security of processing.

```

{
  "article_number": 32,
  "article_title": "Security of processing",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy text focuses on data collection, types of data collected, and user interaction with the platform. It does not contain any information regarding encryption, access

```

controls, incident response, or testing, which are key components of Article 32 of the GDPR concerning the security of processing.",
"status": null,
"gaps": [],
"risk": null
}

Art. 33 — Breach notification to SA

Priority: p3 Chapter: Ch.4 – Controller & processor
Severity: critical Status: missing
Score: 0/100
Notes

The provided text does not contain any information about breach notification to supervisory authorities or DPO contact details. It focuses on data sharing, marketing, and account management.

```
{  
  "article_number": 33,  
  "article_title": "Breach notification to SA",  
  "chapter": "Ch.4 – Controller & processor",  
  "priority": "p3",  
  "policy_present": false,  
  "implementation_unverified": false,  
  "needs_human_review": true,  
  "evidence": [],  
  "notes": "The provided text does not contain any information about breach notification to  
supervisory authorities or DPO contact details. It focuses on data sharing, marketing, and  
account management.",  
  "status": null,  
  "gaps": [],  
  "risk": null  
}
```

Art. 34 — Breach communication to data subject

Priority: p3 Chapter: Ch.4 – Controller & processor
Severity: critical Status: missing
Score: 0/100
Notes

The provided text does not mention or address procedures for communicating data breaches to data subjects, nor does it discuss auto-checking or human review of execution history related to such breaches. The chunks focus on data sharing, marketing, and account management, not breach notification procedures.

```
{  
  "article_number": 34,  
  "article_title": "Breach communication to data subject",  
  "chapter": "Ch.4 – Controller & processor",  
  "priority": "p3",  
  "policy_present": false,  
  "implementation_unverified": false,  
  "needs_human_review": true,  
  "evidence": [],  
  "notes": "The provided text does not mention or address procedures for communicating data  
breaches to data subjects, nor does it discuss auto-checking or human review of execution  
history related to such breaches. The chunks focus on data sharing, marketing, and account  
management, not breach notification procedures.",  
  "status": null,  
  "gaps": [],  
  "risk": null  
}
```

Art. 35 — DPIA

Priority: p3 Chapter: Ch.4 – Controller & processor
Severity: critical Status: missing
Score: 0/100
Notes

The provided text details the types of personal data collected and how it is used, but does not mention or address Data Protection Impact Assessments (DPIAs) or any policy/template related to them.

```
{
```

```

"article_number": 35,
"article_title": "DPIA",
"chapter": "Ch.4 – Controller & processor",
"priority": "p3",
"policy_present": false,
"implementation_unverified": false,
"needs_human_review": true,
"evidence": [],
"notes": "The provided text details the types of personal data collected and how it is used, but does not mention or address Data Protection Impact Assessments (DPIAs) or any policy/template related to them.",
"status": null,
"gaps": [],
"risk": null
}

```

Art. 37 — DPO designation

Priority: p2 **Chapter:** Ch.4 – Controller & processor

Severity: info **Status:** pass

Score: 100/100

Risk: low

Evidence:

- {**policy_chunk_id**: 'c32 20119-21319', **line_number**: 13, **text**: 'If you have privacy concerns or questions, you can contact our European or US Data Protection Officers (DPOs) via email at privacy@patreon.com.']}

Notes:

Patreon states they have DPOs and provides contact details. It is not clear if DPO designation is mandatory based on their processing activities, but the presence of DPOs and contact information is a positive indicator.

```

{
  "article_number": 37,
  "article_title": "DPO designation",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "pass",
  "gaps": [],
  "evidence": [
    {
      "policy_chunk_id": "c32 20119-21319",
      "line_number": 13,
      "text": "If you have privacy concerns or questions, you can contact our European or US Data Protection Officers (DPOs) via email at privacy@patreon.com."
    }
  ],
  "risk": "low",
  "needs_human_review": false,
  "notes": "Patreon states they have DPOs and provides contact details. It is not clear if DPO designation is mandatory based on their processing activities, but the presence of DPOs and contact information is a positive indicator.",
  "article_material_used": "text"
}

```

Art. 38 — DPO position

Priority: p3 **Chapter:** Ch.4 – Controller & processor

Severity: warning **Status:** present (unverified)

Score: 70/100

Notes:

The policy mentions the existence of Data Protection Officers (DPOs) and provides a contact method. However, it does not contain language regarding their independence or reporting lines.

```

{
  "article_number": 38,
  "article_title": "DPO position",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": true,
  "implementation_unverified": true,
  "needs_human_review": true,
  "evidence": "If you have privacy concerns or questions, you can contact our European or US Data Protection Officers (DPOs) via email at privacy@patreon.com.",
  "notes": "The policy mentions the existence of Data Protection Officers (DPOs) and provides a contact method. However, it does not contain language regarding their independence or reporting"
}

```

```
lines.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 39 — DPO tasks

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: critical Status: fail

Score: 0/100

Risk: high

Gaps

- The provided policy chunks do not contain explicit information detailing the specific tasks of the Data Protection Officer (DPO) as required by Article 39 of the GDPR, specifically concerning advising on data protection impact assessments (DPIAs) and cooperating with supervisory authorities.

Evidence

- The policy chunks mention that users can contact DPOs via email at privacy@patreon.com for privacy concerns or questions (c32).

- Patreon states it complies with the GDPR and acts as a Data Controller (c28).

Notes

While the policy indicates the existence of DPOs and provides a contact method, it lacks specifics on the mandated tasks of a DPO as outlined in Article 39, such as advising on DPIAs and cooperating with supervisory authorities.

```
{
  "article_number": 39,
  "article_title": "DPO tasks",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The provided policy chunks do not contain explicit information detailing the specific tasks of the Data Protection Officer (DPO) as required by Article 39 of the GDPR, specifically concerning advising on data protection impact assessments (DPIAs) and cooperating with supervisory authorities."
  ],
  "evidence": [
    "The policy chunks mention that users can contact DPOs via email at privacy@patreon.com for privacy concerns or questions (c32).",
    "Patreon states it complies with the GDPR and acts as a Data Controller (c28)."
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "While the policy indicates the existence of DPOs and provides a contact method, it lacks specifics on the mandated tasks of a DPO as outlined in Article 39, such as advising on DPIAs and cooperating with supervisory authorities.",
  "article_material_used": "summary"
}
```

Art. 40 — Codes of conduct

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

Notes

The policy excerpt is only relevant for understanding terminology used in other articles, not for the topic of this specific article.

```
{
  "article_number": 40,
  "article_title": "Codes of conduct",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": "The provided text contains definitions from GDPR Article 4 and does not address codes of conduct or claims of adherence to them as described in Article 40.",
  "notes": "The policy excerpt is only relevant for understanding terminology used in other
```

```

articles, not for the topic of this specific article.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 42 — Certification

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

Notes

The policy only contains definitions from Article 4 and does not mention certification or the process of verifying certificates.

```

{
  "article_number": 42,
  "article_title": "Certification",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy only contains definitions from Article 4 and does not mention
certification or the process of verifying certificates.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 44 — General principle for transfers

Priority: p2 Chapter: Ch.5 – Transfers to third countries

Severity: warning Status: partial

Score: 44/100

Risk: high

Gaps

- Policy needs to explicitly state that all international transfers comply with Chapter V mechanisms (e.g., SCCs, BCRs, adequacy decisions, etc.).
- Policy needs to specify the mechanisms used for international transfers to countries outside the EEA, as required by Article 44.

Evidence

- Policy chunk [c0 0-491] states: 'Patreon is a global company. By using our platform, you agree that your personal information that you provide directly to us, or that we collect through your use of the platform, may be transferred to and stored in the United States and handled as described in this Policy.' This confirms international transfers occur, but does not specify the Chapter V mechanisms.

Notes

The policy acknowledges that personal data is transferred to and stored in the United States, which is outside the EEA. However, it fails to mention the specific safeguards or mechanisms (e.g., Standard Contractual Clauses, adequacy decisions, etc.) that are in place to ensure compliance with Chapter V of the GDPR for such international transfers. This is a significant gap.

```

{
  "article_number": 44,
  "article_title": "General principle for transfers",
  "chapter": "Ch.5 – Transfers to third countries",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "Policy needs to explicitly state that all international transfers comply with Chapter V
mechanisms (e.g., SCCs, BCRs, adequacy decisions, etc.).",
    "Policy needs to specify the mechanisms used for international transfers to countries
outside the EEA, as required by Article 44."
  ],
  "evidence": [
    "Policy chunk [c0 0-491] states: 'Patreon is a global company. By using our platform, you
agree that your personal information that you provide directly to us, or that we collect

```


through your use of the platform, may be transferred to and stored in the United States and handled as described in this Policy.' This confirms international transfers occur, but does not specify the Chapter V mechanisms."

```
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy acknowledges that personal data is transferred to and stored in the United States, which is outside the EEA. However, it fails to mention the specific safeguards or mechanisms (e.g., Standard Contractual Clauses, adequacy decisions, etc.) that are in place to ensure compliance with Chapter V of the GDPR for such international transfers. This is a significant gap.",
  "article_material_used": "text"
}
```

Art. 45 — Adequacy decision transfers

Priority: p2 Chapter: Ch.5 – Transfers to third countries

Severity: critical Status: fail

Score: 0/100

Risk: critical

Gaps

- No mention of adequacy decisions in the provided policy chunks.

Notes

The provided policy chunks define terms related to GDPR but do not contain information regarding Article 45 (Adequacy decisions) or any references to countries with adequacy decisions. Therefore, compliance cannot be verified.

```
{
  "article_number": 45,
  "article_title": "Adequacy decision transfers",
  "chapter": "Ch.5 – Transfers to third countries",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "No mention of adequacy decisions in the provided policy chunks."
  ],
  "evidence": [],
  "risk": "critical",
  "needs_human_review": false,
  "notes": "The provided policy chunks define terms related to GDPR but do not contain information regarding Article 45 (Adequacy decisions) or any references to countries with adequacy decisions. Therefore, compliance cannot be verified.",
  "article_material_used": "summary"
}
```

Art. 46 — Transfers with safeguards

Priority: p3 Chapter: Ch.5 – Transfers to third countries

Severity: critical Status: missing

Score: 0/100

Notes

The provided text does not contain any mentions of SCCs, BCRs, or other contractual safeguards for international data transfers, which are the core topic of Article 46. It only mentions that data may be transferred to and stored in the US. Therefore, the policy does not materially address the topics of this article.

```
{
  "article_number": 46,
  "article_title": "Transfers with safeguards",
  "chapter": "Ch.5 – Transfers to third countries",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided text does not contain any mentions of SCCs, BCRs, or other contractual safeguards for international data transfers, which are the core topic of Article 46. It only mentions that data may be transferred to and stored in the US. Therefore, the policy does not materially address the topics of this article.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 47 — Binding corporate rules

Priority: p3 Chapter: Ch.5 – Transfers to third countries

Severity: critical Status: missing

Score: 0/100

```
{
  "article_number": 47,
  "article_title": "Binding corporate rules",
  "chapter": "Ch.5 – Transfers to third countries",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": null,
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 49 — Derogations

Priority: p4 Chapter: Ch.5 – Transfers to third countries

Severity: warning Status: triggered (HIL)

Notes

The policy does not explicitly mention Article 49 or derogations, but the prompt specifies that *any* claim related to Article 49 derogations (explicit consent, vital interests) should be flagged for human review, as auto-determination is not feasible. Therefore, triggering this rule is based on the scenario's instruction, not direct policy text.

```
{
  "article_number": 49,
  "article_title": "Derogations",
  "chapter": "Ch.5 – Transfers to third countries",
  "priority": "p4",
  "p4_triggered": true,
  "needs_human_review": true,
  "evidence": "GDPR Article 49: Derogations\nConditional scenario / agent action: Auto-detect
derogation claims (explicit consent, vital interests). Always route to human – applicability
cannot be auto-determined.",
  "what_to_review": [
    "Verify if explicit consent is being relied upon as a basis for data transfer.",
    "Verify if vital interests are being relied upon as a basis for data transfer.",
    "Confirm that these scenarios are not automatically determined and are routed for human
review."
  ],
  "notes": "The policy does not explicitly mention Article 49 or derogations, but the prompt
specifies that any claim related to Article 49 derogations (explicit consent, vital
interests) should be flagged for human review, as auto-determination is not feasible. Therefore,
triggering this rule is based on the scenario's instruction, not direct policy text.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 77 — Right to lodge a complaint

Priority: p2 Chapter: Ch.8 – Remedies, liability & penalties

Severity: critical Status: fail

Score: 0/100

Risk: high

Gaps

- The policy does not inform data subjects of their right to lodge a complaint with a supervisory authority.
- The policy does not provide information on how data subjects can lodge a complaint with a supervisory authority.

Evidence

- { 'policy_chunk_id': 'c21 9930-11130', 'snippet': 'e obligated by contract to safeguard any of your data they receive from us to the same extent that Patreon protects it.\nto protect the security or integrity of Patreon, and

to protect the rights, property, or safety of Patreon, its employees, users, or others, if we believe that disclosure is reasonably necessary to comply with a law, regulation, or other valid legal process (e.g., subpoenas or warrants served on Patreon). If we are going to release your data, we will do our best to provide you promptly with notice by email, unless we are prohibited by law from doing so.

In connection with the sale, merger, bankruptcy, sale of assets or reorganization of our company. We will notify you if a different company receives your data. The promises in this privacy policy apply to any data transferred to a new entity.

With third party apps used by creators to help run their membership programs. There is a list of apps in our apps directory. While we try to keep this list up to date, we often experiment with new third party app providers, and this list may not be exhaustive.

With partners in our Partners Directory, who may have access to your data to perform their services, and who are obligated

- {policy_chunk_id: 'c22 10930-11939', 'snippet': 'In connection with new third party app providers, and this list may not be exhaustive. In connection with partners in our Partners Directory, who may have access to your data to perform their services, and who are obligated by contract to safeguard any of your data they receive from us to the same extent that Patreon protects it.'}

Information Patreon Collects from Third Party Apps

When you create a Patreon account, you can elect to connect your social account(s) (e.g. Twitter, Facebook, Google, YouTube, Twitch) with Patreon, and we will collect and store some social information from those platforms, such as:

- follower or subscriber counts
- post or upload counts
- view, like, and comment counts

This social information allows us to provide you a better Patreon experience, and also helps guide future development of Patreon. We use this data to:

- help creators and patrons find each other on Patreon
- assess how to make creators more successful on Patreon
- analyze and describe our business

Information We Share with the Public

- {policy_chunk_id: 'c23 11939-12592', 'snippet': 'The following information is publicly accessible: your profile, and your social media links and location if you add that information. By default the creators you support are publicly displayed. If you flag your account as private, we will not display the creators you support. Any posts, likes, or comments you make. Your aggregated or anonymized usage data in blog posts, press releases, or in other ways to share information about Patreon's usage. Aggregated or anonymized data cannot be linked back to any individual Patreon user. Monthly pledge value and goals that creators choose to make public. Number of patrons. Your Preferences and Rights over Data'}

- {policy_chunk_id: 'c24 12592-12925', 'snippet': 'Choosing Your Preferences. The Settings link is located by clicking on your avatar or profile at the top right hand of your screen, after your log into your Patreon account. Settings lets you see your account preferences. You can see and adjust your settings by viewing your preferences and, if you wish, by changing your selections.'}

- {policy_chunk_id: 'c25 12925-14125', 'snippet': 'Marketing Activities. By agreeing to our terms of use, you expressly agree that Patreon may: provide you with information about your service, service enhancements, or new Patreon products, while you are on our web site or using our apps. Send you messages regarding your existing service, or enhancements related to your existing service, when you are off our platform, via email, or via text, if you have signed up for a service or event notification that uses text messages. Send you messages related to services we provide which are separate from your existing service via email, from which you may opt out. Market Patreon to you and audiences similar to you based on your networks and common factors that others have with you, unless you opt out. Send you marketing emails or texts if you don't have a Patreon account but have consented to receiving such messages, from which you may opt out. Ask for demographic information to spotlight and celebrate creators. Promote your account for greater discoverability. Ship physical items to you via mail as part of a promotional activity. Opting out of Marketing'}

- {policy_chunk_id: 'c26 13925-15076', 'snippet': 'Discoverability. Ship physical items to you via mail as part of a promotional activity. Opting out of Marketing. You may object to the use of your data for marketing purposes at any time, free of charge, when we collect your personal information and in every marketing communication. You may also object to the use of your data for marketing upon creation of your account or anytime thereafter, by opting out here. Opting out will stop marketing emails. Please allow up to 30 days for your opt-out request to be processed. If you have an account with Patreon, you will continue to receive service-related emails, and texts, if you have opted into receiving texts. You will also continue to receive service-related shipments of benefits to the designated delivery address. We will never sell your information to third parties for marketing purposes without your prior consent. Accessing, Updating or Exporting the Information in Your Account. You can access and update certain information associated with your account on the settings pages. Additionally,

you can delete your account, or export your personal information, by going to privacy.patreon.com.”}

- {‘policy_chunk_id’: ‘c27 15076-16276’, ‘snippet’: ‘Deleting Your Account\nYou may self-initiate a deletion of your account directly at privacy.patreon.com, clicking on the Take Control button, and submitting an “Erase” request. Please be aware that this is a final act and cannot be reversed. If you would like to transport your data, please be sure to download your data first,’}

Notes

The policy fails to inform data subjects of their right to lodge a complaint with a supervisory authority and how to do so, as required by GDPR Article 77. There is no mention of supervisory authorities or the process for lodging a complaint.

```
{
  "article_number": 77,
  "article_title": "Right to lodge a complaint",
  "chapter": "Ch.8 – Remedies, liability & penalties",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not inform data subjects of their right to lodge a complaint with a supervisory authority.",
    "The policy does not provide information on how data subjects can lodge a complaint with a supervisory authority."
  ],
  "evidence": [
    {
      "policy_chunk_id": "c21 9930-11130",
      "snippet": "e obligated by contract to safeguard any of your data they receive from us to the same extent that Patreon protects it.\nnto protect the security or integrity of Patreon, and to protect the rights, property, or safety of Patreon, its employees, users, or others, if we believe that disclosure is reasonably necessary to comply with a law, regulation, or other valid legal process (e.g., subpoenas or warrants served on Patreon). If we are going to release your data, we will do our best to provide you promptly with notice by email, unless we are prohibited by law from doing so.\nin connection with the sale, merger, bankruptcy, sale of assets or reorganization of our company. We will notify you if a different company receives your data. The promises in this privacy policy apply to any data transferred to a new entity.\nwith third party apps used by creators to help run their membership programs. There is a list of apps in our apps directory. While we try to keep this list up to date, we often experiment with new third party app providers, and this list may not be exhaustive.\nwith partners in our Partners Directory, who may have access to your data to perform their services, and who are oblig"
    },
    {
      "policy_chunk_id": "c22 10930-11939",
      "snippet": "periment with new third party app providers, and this list may not be exhaustive.\nwith partners in our Partners Directory, who may have access to your data to perform their services, and who are obligated by contract to safeguard any of your data they receive from us to the same extent that Patreon protects it.\nInformation Patreon Collects from Third Party Apps\nWhen you create a Patreon account, you can elect to connect your social account(s) (e.g. Twitter, Facebook, Google, YouTube, Twitch) with Patreon, and we will collect and store some social information from those platforms, such as:\nfollower or subscriber counts\npost or upload counts\nview, like, and comment counts\nThis social information allows us to provide you a better Patreon experience, and also helps guide future development of Patreon. We use this data to:\nhelp creators and patrons find each other on Patreon\nassess how to make creators more successful on Patreon\nanalyze and describe our business\nInformation We Share with the Public"
    },
    {
      "policy_chunk_id": "c23 11939-12592",
      "snippet": "The following information is publicly accessible:\nyour profile, and your social media links and location if you add that information\nby default the creators you support are publicly displayed. If you flag your account as private, we will not display the creators you support\nany posts, likes, or comments you make\nyour aggregated or anonymized usage data in blog posts, press releases, or in other ways to share information about Patreon’s usage. Aggregated or anonymized data cannot be linked back to any individual Patreon user\nmonthly pledge value and goals that creators choose to make public\nnumber of patrons\nYour Preferences and Rights over Data"
    },
    {
      "policy_chunk_id": "c24 12592-12925",
      "snippet": "Choosing Your Preferences\nThe Settings link is located by clicking on your avatar or profile at the top right hand of your screen, after your log into your Patreon account. Settings lets you see your account preferences. You can see and adjust your settings by viewing your preferences and, if you wish, by changing your selections."
    },
    {
      "policy_chunk_id": "c25 12925-14125",
      "snippet": "Marketing Activities\nBy agreeing to our terms of use, you expressly agree that Patreon may:\nprovide you with information about your service, service enhancements, or new Patreon products, while you are on our web site or using our apps.\nsend you messages regarding your existing service, or enhancements related to your existing service, when you are
```

off our platform, via email, or via text, if you have signed up for a service or event notification that uses text messa
... (truncated)

Art. 85 — Freedom of expression

Priority: p4 Chapter: Ch.9 – Specific processing situations

Severity: warning Status: triggered (HIL)

Notes

Article 85 derogations are complex and require human review to assess legitimacy and compatibility with fundamental rights.

```
{
  "article_number": 85,
  "article_title": "Freedom of expression",
  "chapter": "Ch.9 – Specific processing situations",
  "priority": "p4",
  "p4_triggered": true,
  "needs_human_review": true,
  "evidence": "Auto-detect journalism/academic/artistic derogation claims. Always route to human – legitimacy cannot be auto-verified.",
  "what_to_review": [
    "Verify if the user is claiming a journalism, academic, or artistic derogation under Article 85.",
    "Assess the legitimacy of the claimed derogation.",
    "Determine if the processing is compatible with fundamental rights and freedoms."
  ],
  "notes": "Article 85 derogations are complex and require human review to assess legitimacy and compatibility with fundamental rights.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 87 — National identification number

Priority: p4 Chapter: Ch.9 – Specific processing situations

Severity: warning Status: triggered (HIL)

Notes

Article 87 applies to the processing of national identification numbers. The policy mentions 'Social Security Number or Employer Identification Number' which are often national identification numbers. Further review is needed to confirm if these are treated as such under the relevant national laws and to assess the safeguards.

```
{
  "article_number": 87,
  "article_title": "National identification number",
  "chapter": "Ch.9 – Specific processing situations",
  "priority": "p4",
  "p4_triggered": true,
  "needs_human_review": true,
  "evidence": "Social Security Number or Employer Identification Number",
  "what_to_review": [
    "Verify if 'Social Security Number' or 'Employer Identification Number' are considered national identification numbers under applicable national law.",
    "Review the safeguards in place for the collection and processing of these numbers.",
    "Check if there is a specific legal basis for processing national identification numbers.",
    "Assess whether the processing is necessary and proportionate for the stated purposes."
  ],
  "notes": "Article 87 applies to the processing of national identification numbers. The policy mentions 'Social Security Number or Employer Identification Number' which are often national identification numbers. Further review is needed to confirm if these are treated as such under the relevant national laws and to assess the safeguards.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 88 — Employment context

Priority: p2 Chapter: Ch.9 – Specific processing situations

Severity: critical Status: fail

Score: 0/100

Risk: critical

Gaps

- The policy does not explicitly address the collection, processing, or retention of employee data in the context of recruitment, health and safety, or termination.
- There is no mention of specific safeguards or procedures related to employee monitoring within the employment context.
- The policy lacks details on how employee data is handled during the termination process, including data retention and deletion.

Evidence

- The provided text focuses heavily on user data collection for a platform's services, not specifically on employee data within an employment relationship governed by Article 88.
- While some data points like 'Address' and 'Phone Number' are mentioned, their collection and use in an employment context are not detailed.

Notes

Article 88 of GDPR permits Member States to specify rules for the processing of personal data in the employment context. The provided policy does not contain any specific clauses addressing employment relationships, and therefore cannot be assessed against the requirements of Article 88. The general data collection practices outlined are for users of a service, not employees. This represents a significant gap in addressing employee privacy as required by GDPR Article 88.

```
{
  "article_number": 88,
  "article_title": "Employment context",
  "chapter": "Ch.9 - Specific processing situations",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not explicitly address the collection, processing, or retention of employee data in the context of recruitment, health and safety, or termination.",
    "There is no mention of specific safeguards or procedures related to employee monitoring within the employment context.",
    "The policy lacks details on how employee data is handled during the termination process, including data retention and deletion."
  ],
  "evidence": [
    "The provided text focuses heavily on user data collection for a platform's services, not specifically on employee data within an employment relationship governed by Article 88.",
    "While some data points like 'Address' and 'Phone Number' are mentioned, their collection and use in an employment context are not detailed."
  ],
  "risk": "critical",
  "needs_human_review": false,
  "notes": "Article 88 of GDPR permits Member States to specify rules for the processing of personal data in the employment context. The provided policy does not contain any specific clauses addressing employment relationships, and therefore cannot be assessed against the requirements of Article 88. The general data collection practices outlined are for users of a service, not employees. This represents a significant gap in addressing employee privacy as required by GDPR Article 88.",
  "article_material_used": "text"
}
```

Appendix — human review queue

```
[
  {
    "kind": "p3_verify",
    "article_number": 8,
    "article_title": "Child's consent",
    "policy_present": true,
    "implementation_unverified": true,
    "evidence": "Patreon is not directed at children under the age of 13, and children may not
create an account or otherwise use Patreon.",
    "notes": "The policy explicitly states that the service is not directed at children under
13 and that children cannot create an account or use the service. This directly addresses the
age limitation aspect of Article 8. However, it does not mention parental consent mechanisms."
  },
  {
    "kind": "p3_verify",
    "article_number": 10,
    "article_title": "Criminal convictions data",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": null
  },
  {
    "kind": "p3_verify",
    "article_number": 19,
    "article_title": "Notification on rectification/erasure",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy text does not contain any information about notifying recipients of
rectification or erasure of personal data. The provided chunks discuss data sharing with third
parties, legal disclosures, and account deletion, but not the specific notification requirement
under Article 19."
  },
  {
    "kind": "p3_verify",
    "article_number": 25,
    "article_title": "Privacy by design and default",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text discusses data collection, usage, sharing, and user preferences,
but it does not explicitly mention or address the principles of 'privacy by design' or
'privacy by default' as required by Article 25 of the GDPR. While some sections touch upon
default settings for public display of creators supported (c23), this is not sufficient to
constitute a material mention of the core concepts of PbD/PbDf."
  },
  {
    "kind": "p3_verify",
    "article_number": 26,
    "article_title": "Joint controllers",
    "policy_present": true,
    "implementation_unverified": true,
    "evidence": "The definition of 'controller' in Article 4(7) explicitly states 'determines
the purposes and means of the processing of personal data; where the purposes and means of such
processing are determined by Union or Member State law, the controller or the specific criteria
for its nomination may be provided for by Union or Member State law'. This wording implies that
multiple entities can be controllers, either 'alone or jointly with others', thus addressing
the concept of joint controllership.",
    "notes": "The provided text includes definitions relevant to Article 26, specifically the
definition of 'controller', which inherently covers joint controllership. The definition
implies that the determination of purposes and means can be made by multiple entities. Thus,
the policy materially addresses the topic."
  },
  {
    "kind": "p3_verify",
    "article_number": 27,
    "article_title": "Representatives (non-EU)",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided policy text contains definitions from GDPR Article 4, but does not
address the specific requirements of Article 27 concerning the appointment of a representative
for non-EU entities."
  },
  {
    "kind": "p3_verify",
    "article_number": 32,
    "article_title": "Security of processing",
  }
]
```

```

    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy text focuses on data collection, types of data collected, and user
interaction with the platform. It does not contain any information regarding encryption, access
controls, incident response, or testing, which are key components of Article 32 of the GDPR
concerning the security of processing."
  },
  {
    "kind": "p3_verify",
    "article_number": 33,
    "article_title": "Breach notification to SA",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text does not contain any information about breach notification to
supervisory authorities or DPO contact details. It focuses on data sharing, marketing, and
account management."
  },
  {
    "kind": "p3_verify",
    "article_number": 34,
    "article_title": "Breach communication to data subject",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text does not mention or address procedures for communicating data
breaches to data subjects, nor does it discuss auto-checking or human review of execution
history related to such breaches. The chunks focus on data sharing, marketing, and account
management, not breach notification procedures."
  },
  {
    "kind": "p3_verify",
    "article_number": 35,
    "article_title": "DPIA",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text details the types of personal data collected and how it is used,
but does not mention or address Data Protection Impact Assessments (DPIAs) or any policy/
template related to them."
  },
  {
    "kind": "p3_verify",
    "article_number": 38,
    "article_title": "DPO position",
    "policy_present": true,
    "implementation_unverified": true,
    "evidence": "If you have privacy concerns or questions, you can contact our European or US
Data Protection Officers (DPOs) via email at privacy@patreon.com.",
    "notes": "The policy mentions the existence of Data Protection Officers (DPOs) and provides
a contact method. However, it does not contain language regarding their independence or
reporting lines."
  },
  {
    "kind": "p3_verify",
    "article_number": 40,
    "article_title": "Codes of conduct",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": "The provided text contains definitions from GDPR Article 4 and does not
address codes of conduct or claims of adherence to them as described in Article 40.",
    "notes": "The policy excerpt is only relevant for understanding terminology used in other
articles, not for the topic of this specific article."
  },
  {
    "kind": "p3_verify",
    "article_number": 42,
    "article_title": "Certification",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy only contains definitions from Article 4 and does not mention
certification or the process of verifying certificates."
  },
  {
    "kind": "p3_verify",
    "article_number": 46,
    "article_title": "Transfers with safeguards",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text does not contain any mentions of SCCs, BCRs, or other

```


contractual safeguards for international data transfers, which are the core topic of Article 46. It only mentions that data may be transferred to and stored in the US. Therefore, the policy does not materially address the topics of this article."

```
    },
    {
      "kind": "p3_verify",
      "article_number": 47,
      "article_title": "Binding corporate rules",
      "policy_present": false,
      "implementation_unverified": false,
      "evidence": [],
      "notes": null
    },
    {
      "kind": "p4_conditional",
      "article_number": 49,
      "article_title": "Derogations",
      "what_to_review": [
        "Verify if explicit consent is being relied upon as a basis for data transfer.",
        "Verify if vital interests are being relied upon as a basis for data transfer.",
        "Confirm that these scenarios are not automatically determined and are routed for human review."
      ],
      "evidence": "GDPR Article 49: Derogations\nConditional scenario / agent action: Auto-detect derogation claims (explicit consent, vital interests). Always route to human – applicability cannot be auto-determined.",
      "notes": "The policy does not explicitly mention Article 49 or derogations, but the prompt specifies that *any* claim related to Article 49 derogations (explicit consent, vital interests) should be flagged for human review, as auto-determination is not feasible. Therefore, triggering this rule is based on the scenario's instruction, not direct policy text."
    },
    {
      "kind": "p4_conditional",
      "article_number": 85,
      "article_title": "Freedom of expression",
      "what_to_review": [
        "Verify if the user is claiming a journalism, academic, or artistic derogation under Article 85.",
        "Assess the legitimacy of the claimed derogation.",
        "Determine if the processing is compatible with fundamental rights and freedoms."
      ],
      "evidence": "Auto-detect journalism/academic/artistic derogation claims. Always route to human – legitimacy cannot be auto-verified.",
      "notes": "Article 85 derogations are complex and require human review to assess legitimacy and compatibility with fundamental rights."
    },
    {
      "kind": "p4_conditional",
      "article_number": 87,
      "article_title": "National identification number",
      "what_to_review": [
        "Verify if 'Social Security Number' or 'Employer Identification Number' are considered national identification numbers under applicable national law.",
        "Review the safeguards in place for the collection and processing of these numbers.",
        "Check if there is a specific legal basis for processing national identification numbers."
      ],
      "evidence": "Social Security Number or Employer Identification Number",
      "notes": "Article 87 applies to the processing of national identification numbers. The policy mentions 'Social Security Number or Employer Identification Number' which are often national identification numbers. Further review is needed to confirm if these are treated as such under the relevant national laws and to assess the safeguards."
    }
  ]
}
```